

COMPLETED SECURITY AUDIT ASSIGNMENT

Question 1: what did I do?

For this assignment, I selected a small business within my neighborhood, a nail salon that I regularly visit, as the subject of my operational audit. I approached the owner with a proposal to conduct a basic cybersecurity and operational assessment to evaluate how well the salon's systems and physical environment are protected. The primary purpose of the audit was to examine their cybersecurity posture, operational efficiency, and physical security measures to ensure the protection of customer data, payment systems, and business operations.

I explained to the owner that the outcome of this audit would likely reveal potential security gaps and operational inefficiencies. After receiving permission, I began the assessment by reviewing both digital and physical assets. I checked the strength of their passwords, verified system updates, evaluated the effectiveness of their data backup procedures, and tested the security of their Wi-Fi network and firewall configuration.

In addition to technical checks, I explored how the salon manages employee and customer information, including credit card data and client privacy records. I also reviewed their incident response plan, data disposal methods, and license and compliance documentation to ensure the business was aligned with regulatory and safety standards. Toward the end of the visit, I inspected the physical environment, including electrical outlets and surge protectors, to confirm adequate protection. I also examined how mobile devices used for business purposes were secured, ensuring they were password-protected or otherwise safeguarded against unauthorized access.

The Audit Report

Purpose

The purpose of this audit plan is to evaluate the cybersecurity posture, operational compliance, and data protection measures of the nail salon. The assessment aims to ensure that customer data, including payment information and client records, are securely managed, that business continuity is maintained through effective controls, and that the salon complies with general regulatory and industry best practices.

Outcome

The expected outcome of the audit is to identify existing security gaps, operational risks, and areas for improvement while documenting key findings and offering actionable recommendations. The goal is to help the salon align its cybersecurity and operational practices

with small-business security frameworks and best-practice standards to strengthen its resilience and data protection capabilities.

Scope

The scope of the audit covered both digital and physical components of the salon's operations, including:

- IT systems (Point-of-Sale, booking applications, and Wi-Fi configuration)
- Staff devices and access controls
- Data backup procedures and privacy practices
- Physical and environmental safety controls (surge protection, CCTV, fire safety)
- Vendor and payment processing security compliance
- Employee awareness of cybersecurity practices and daily operational procedures

Audit Procedure

Arrival:

Upon arrival at noon, I met with the salon owner and manager to explain the purpose of the audit, confirm access to relevant systems (Wi-Fi, POS terminals, and employee devices), and verify written and verbal consent for non-intrusive system checks.

Introduction:

I outlined the audit's objectives, scope, and methodology, emphasizing confidentiality of results and the importance of transparency during the process. We also agreed to a timeline for the audit and an end-of-day debrief to review key observations.

Audit Meeting:

After the audit was completed, I presented the findings to the owner, categorized identified risks as low, medium, or high, and discussed actionable recommendations for each issue. We agreed on corrective action steps, accountability assignments, and a realistic timeline for implementation.

Audit Hot Wash: Once the attached Audit Plan document was completed, I informed the nail salon manager that the audit activities had concluded and proceeded to conduct a post-audit meeting. The purpose of this meeting was to review and discuss the initial findings, highlight areas of concern, and ensure the manager clearly understood each observation. Together, we collaborated to develop and agree upon an action plan, outlining specific corrective measures, any additional information required, and potential recommendations for improving the salon's cybersecurity and operational practices. This debrief served as an important opportunity to validate results, align priorities, and reinforce the salon's commitment to strengthening its overall security posture.

Audit Commenced (time/date): 12:00 PM, November 7, 2025

Audit Complete (time/date): 2:30 PM, November 7, 2025

Auditor: Tiwa Shadare.

Item #	Description	Expected Findings/pass criteria	Observations	Pass? (Yes/No)
1	Check password strength	All accounts (POS, Wi-Fi, devices, social media) use strong passwords: ≥12 characters, mix of cases, numbers, symbols.	Two staff accounts use “nailsalon123” and “welcome2024”.	No
2	Check for missing updates	All systems and apps (POS, browsers, OS, antivirus) updated within last 30 days.	Reception laptop overdue by 45 days.	No
3	Check for back ups	Automated or manual backups verified (daily/weekly) to cloud or external drive.	Cloud backup active; local drive last used 2 weeks ago.	Yes
4	Review antivirus/antimalware protection	Licensed software installed, updated, and performing scheduled scans.	AVG up to date; clean logs.	Yes
5	Check Wi-Fi security	WPA3/WPA2 encryption; hidden SSID optional; guest network separated from POS/office network.	Guest Wi-Fi open, no password.	No
6	Inspect firewall settings	Hardware/software firewall enabled and logging.	Active on all systems.	Yes
7	Review user access control	Only authorized staff have system login access; terminated employees' access revoked.	Ex-employee's login access not revoked	No
8	Review POS system security	Transactions encrypted; customer data not stored locally; PCI-DSS compliant.	POS cloud-based and PCI compliant; tested for encryption.	Yes
9	Review physical security	Security cameras functional; cash register and storage areas locked after hours.	Cameras cover front and back; no blind spots.	Yes
10	Inspect workstation security	Screens auto-lock after 5 minutes of inactivity; minimal use of USB drives.	Auto-lock set at 15 mins; recommend shorter timeout.	No (Maybe)
11	Evaluate data privacy practices	Client records securely stored; consent forms compliant with privacy policy.	Customers forms locked and encrypted	Yes
12	Check incident response preparedness	Staff know whom to contact in event of cyber incident; documented plan exists.	No written plan; verbal process only.	No

13	Verify staff training	Employees trained on phishing, password hygiene, and customer data handling.	Informal only; no records kept.	No
14	Review third-party services	Verify that third-party vendors (POS provider, booking apps) follow secure practices.	Booking app uses HTTPS and MFA; verified.	Yes
15	Check business continuity plan	Recovery steps documented; essential contacts and backup sources listed.	No formal plan on file.	No
16	Test website security (if applicable)	HTTPS enabled; SSL certificate valid.	SSL valid through 2026.	Yes
17	Inspect IoT devices (e.g., cameras, smart locks)	Default passwords changed; firmware updated; devices isolated on guest or IoT network.	Smart thermostat using default password.	No
18	Review client booking software	Platform uses encrypted connections (HTTPS) and 2FA enabled	2FA not enabled for receptionist login	No
19	Environmental and safety audit	Fire extinguisher and first aid kits accessible; emergency exits clear.	Fire extinguisher checked; exits clear.	Yes
20	Data disposal	Sensitive data shredded/wiped.	Shred bin used; digital files deleted securely.	Yes
21	Device inventory	Inventory maintained and labeled.	Spreadsheet last updated June 2025.	No
22	Internet speed and reliability	Internet connection stable and secure.	Stable 200 Mbps; minor dropouts noted.	Yes
23	VPN usage for remote access	Staff use VPN for offsite access.	No VPN in place; direct logins used.	No
24	Social media account security	Business pages secured with MFA.	Instagram protected; Facebook lacks MFA.	No
25	Printer and shared devices	No sensitive data left on printers.	Printer logs clear; sensitive pages shredded.	Yes
26	Surveillance data storage	Security footage stored securely and deleted after retention period.	Footage stored locally; no retention policy.	No
27	Mobile device management	Salon phones/tablets secured by PIN or biometrics.	Owner's phone secured; staff phone lacks passcode.	No
28	Electrical and surge protection	All major equipment on surge protectors.	All major equipment, POS, and computers protected.	Yes
29	Check ports using ShieldsUP	Ports are in stealth or closed	Port 21 (FTP) found open; likely unused remote admin service.	No

30	License and compliance checks	All licenses and insurance valid.	Licenses and Insurance current and displayed	Yes
----	-------------------------------	-----------------------------------	--	-----

Question 2: what were the results?

During the audit, several strengths and weaknesses were observed across the nail salon's cybersecurity, operational, and physical environments. The salon demonstrated good practices in certain areas, such as maintaining up-to-date antivirus protection, using a secure POS system that complies with PCI-DSS standards, and properly locking away paper client records to protect customer privacy. Physical safety controls, such as security cameras, fire extinguishers, and clear emergency exits, were also well maintained. These elements indicate that the business owner values safety and operational continuity.

However, there were also several areas that require attention. The most notable weaknesses included weak employee passwords, an open guest Wi-Fi network, and outdated system updates on one workstation. The absence of a formal incident response and business continuity plan poses additional risk in the event of a data breach or system failure. While cloud backups were functioning, local backups were inconsistent. Some IoT devices, such as the smart thermostat, still used default credentials, and employee cybersecurity awareness training was informal and undocumented. These findings suggest that while the salon has made commendable progress in basic security measures, it would benefit from implementing stronger administrative controls, employee training, and consistent technical maintenance to achieve a more resilient cybersecurity position.

Question 3: What did I learn? (Recommendations)

Based on the results of the audit, the overall risk posture of the salon is best described as **Moderate Risk**, several improvements are recommended to strengthen the nail salon's cybersecurity and operational posture. First, the salon should immediately address their greatest vulnerability, which is to implement stronger password policies, requiring at least twelve-character passwords that include a combination of letters, numbers, and symbols. All default passwords, particularly those on smart devices such as thermostats and cameras, should be changed. The open guest Wi-Fi network should be secured with a password and segmented from the main business network to prevent unauthorized access to systems handling payment or customer data. Additionally, regular system updates should be enforced on all devices, and a reputable VPN service should be used for any remote access to business platforms.

From a policy and management perspective, the salon should establish a formal incident response plan and a business continuity plan outlining procedures for handling data breaches,

system failures, or physical incidents. Employee cybersecurity training should be conducted at least annually, covering topics such as phishing awareness, safe data handling, and password hygiene. The salon should also review its third-party vendor contracts to ensure they include data protection clauses and align with privacy best practices. Finally, implementing simple but consistent network monitoring, backup verification, and documentation of security policies will help the salon maintain compliance, safeguard customer trust, and reduce future operational risks.

The salon has a strong foundation to build upon, and most of the identified risks can be mitigated quickly through low-cost best practices. With timely implementation of the recommended improvements, the salon can shift from a moderate-risk posture to a low-risk posture in a relatively short period of time. Based on my audit findings, I created a Cybersecurity Improvement Action Plan:

#	Issue/ Gap Identified	Recommended Action	Priority	Responsible Party	Timeline/ Due Date
1	Weak staff passwords (e.g., “nailsalon123”)	Implement a strong password policy (12+ characters, mix of upper/lowercase, numbers, symbols). Use a password manager if possible.	High	Salon Manager / All Staff	Within 1 week
2	Open guest Wi-Fi with no password	Secure guest Wi-Fi with a password and ensure it’s on a separate network from business systems.	High	IT Support / Wi-Fi Provider	Within 1 week
3	Outdated system updates on one workstation	Enable automatic updates on all computers and mobile devices; verify monthly.	High	Salon Manager	Within 2 weeks
4	No formal incident response plan	Create a written incident response plan outlining what to do in case of data loss, hack, or payment issue. Train staff on the procedure.	High	Salon Manager / External Consultant	Within 3 weeks
5	No formal business continuity plan	Develop a short plan documenting backup location, emergency contacts, and recovery procedures	Medium	Salon Manager	Within 4 weeks
6	Ex-employee account still active	Review and remove all inactive employee accounts from computers, POS and booking systems.	High	Salon Manager	Within 1 week

7	Smart thermostat using default password	Change default credentials on all IoT devices (thermostats, cameras, smart locks).	Medium	Salon Manager	Within 2 weeks
8	Staff not trained on cybersecurity	Schedule a 1-hour cybersecurity awareness session (phishing, password safety, device use).	High	Salon Manager / External Consultant	Within 3 weeks
9	Missing VPN for remote logins	Install a reputable VPN service for any remote management or POS access.	Medium	IT Support	Within 4 weeks
10	Inconsistent local backups	Set automated weekly local backups and verify cloud backups monthly.	Medium	Salon Manager	Within 2 weeks
11	No data retention period for surveillance footage	Establish a 30-day retention policy for camera footage and delete old data securely.	Low	Salon Manager	Within 6 weeks
12	Social media page without MFA	Enable multi-factor authentication (MFA) on all social media and business accounts	Medium	Salon Manager	Within 2 weeks
13	Open Ports on Computers	Ensure that all Ports are in Stealth or Closed mode	High	Salon Manager	Within 1 week

Implementation Phases

Phase 1 (Week 1–2): Immediate Security Enhancements

- Fix weak passwords and remove old accounts.
- Secure Wi-Fi network.
- Close open ports.
- Update systems and change default device credentials.

Phase 2 (Week 3–4): Policy and Awareness Building

- Develop an incident response and business continuity plan.
- Conduct staff cybersecurity training.
- Enable VPN and MFA on key accounts.

Phase 3 (Week 5–6): Long-Term Risk Management

- Implement surveillance data retention policies.
- Review and test all backup and recovery procedures.

Conclusion

This project helped me better understand how even small businesses, like a neighborhood nail salon, face real security risks despite their size. Many small organizations operate under the misconception that they are too small to be targeted, yet they handle sensitive customer data such as credit card details, contact information, and booking records that can be valuable to attackers. Through this audit, I learned how essential it is for every business, no matter how small, to have foundational security controls in place, including strong passwords, up-to-date systems, secure Wi-Fi networks, and regular data backups.

Another key lesson I gained is the importance of combining technical security with operational discipline. For example, even though the salon's antivirus protection and payment systems were strong, areas like password management, employee access control, and incident response planning needed improvement. This reinforced that cybersecurity is not just about technology, it's also about people, policies, and consistent practices. Finally, I learned the value of communicating technical findings in a way that non-technical business owners can understand and act upon. Being able to explain risks in simple terms and suggest realistic solutions is just as important as identifying the vulnerabilities themselves.